

DPIA — KEYBOX Coach Health Vault (`coach.keybox.fyi`)

This is the product-specific DPIA for the `coach.keybox.fyi` surface. It supplements and supersedes the `shystore-v1` SDK DPIA (`DPIA_CONFIDENTIAL_STORE_KEYLESS_RECOVERY.tex`) for deployments involving EHR health data.

EHR EXTENSION — Art. 9 / HIPAA POSTURE

This section applies when `shyconfig.store.secret_categories` includes `health_record` or `health_record_era` and `shyconfig.store.ehr_provider` is set (e.g. `epic`). It supplements the generic confidential-store DPIA above.

Processing Surface — EHR Deployments

Surface	Description
<code>coach.keybox.fyi</code>	Patient-facing EHR vault console. Patient imports FHIR health records (Observation, MedicationRequest, Condition, etc.).
<code>authenticator.keybox.fyi</code>	TOTP/FIDO2 seed vault. Competes with Google Authenticator and Authy. Stores TOTP seeds.
<code>keybox.fyi</code>	Public splash only. No health data. No TOTP seeds.

Art. 9 Lawful Basis — Special Category Health Data

Health records are special-category personal data under GDPR Art. 9(1). Processing requires an explicit exemption under Art. 9(2). The intended basis for KEYBOX EHR deployments is:

- **Art. 9(2)(a) — Explicit consent.** The data subject provides freely given, specific, informed, and unambiguous consent to processing of their health data for the purpose of personal health record vaulting and selective disclosure. Consent must be granular per FHIR resource type (e.g. Observation, MedicationRequest, Condition separately).
- **Consent record architecture.** A consent record is written to List 2 of the `shy-store` ledger via `POST /api/store/consent` with `category: health_record`, `basis: explicit_consent`, and a scoping identifier. The consent record is itself subject to Art. 17 erasure via `DELETE /api/store/consent/:consentId`. The Stack 4 EHR assertion suite (EHR section of `keybox.unit.mjs`) tests this endpoint.
- **Withdrawal path.** Withdrawal of consent triggers deletion of all associated `health_record` and `health_record_era` secrets plus the consent record itself. The Art. 17 erasure path (ERASURE section, VERIFIED run 26369476939) covers the canonical deletion step; operator must additionally purge off-chain linkage, backup, and FHIR-provider-side authorisation.

Required operator action: Before EHR payloads flow in production, a counsel-reviewed consent UI must be deployed at `coach.keybox.fyi` that records Art. 9(2)(a) consent per resource type. Shyware does not provide the consent UI.

HIPAA Applicability

If the KEYBOX deployment processes Protected Health Information (PHI) of US persons in connection with a covered entity or business associate, HIPAA applies independently of GDPR.

Sub-processor	HIPAA role	BAA
AWS (KMS, EC2, S3 Object Lock)	Business Associate	BAA
CockroachDB (off-chain linkage)	Business Associate	BAA
Didit (biometric break-glass fallback only)	Business Associate (identity context only; no PHI payload)	BAA
Epic (FHIR source)	Covered Entity / data source	Patie

VITE_FHIR_CLIENT_ID must be set in CI secrets before the Epic SMART on FHIR flow is wired. The CI build environment currently passes this variable empty; any production build must populate it from a registered Epic client ID.

Selective Disclosure Architecture

`shyconfig.store.selective_disclosure: true` declares that the reconciling authority API must accept a `category` filter parameter and return only matching sealed blobs. The Stack 4 EHR assertion suite verifies:

Assertion	Endpoint
<code>health_record</code> store → 201, <code>secretId</code> returned	POST <code>/api/store/</code>
<code>health_record_era</code> store → 201, <code>secretId</code> returned	POST <code>/api/store/</code>
Retrieve <code>health_record</code> → <code>secretId</code> present, no <code>identityHash</code>	GET <code>/api/store/s</code>
Selective disclosure: <code>health_record</code> request does not return <code>health_record_era</code> <code>secretId</code>	GET <code>/api/store/s</code>
Cross-participant isolation: Bob cannot retrieve Alice's health record	GET <code>/api/store/s</code>
Art. 9 consent record → 200/201, <code>consentId</code> returned	POST <code>/api/store/</code>
Bulk EHR enumeration → 403	GET <code>/api/store/s</code>
Art. 17 EHR erasure → 200/204	DELETE <code>/api/stor</code>
Post-erasure retrieval → 404	GET <code>/api/store/s</code>

EHR residual risk after controls:

Risk	Control
No Art. 9 lawful basis before EHR flows	Consent endpoint + counsel UI required
HIPAA BAA absent	BAA with AWS, CockroachDB, Didit required
FHIR client secret exposed in CI	VITE_FHIR_CLIENT_ID must be set in secrets; currently empty
Selective-disclosure category leak	Stack 4 EHR assertion suite; category filter on reconcile API
Incomplete EHR erasure (FHIR-side)	Operator must revoke Epic SMART token + delete local authorisation

EHR extension verdict: The shystore structural layer (two-list invariant, sealed payload, Art. 17 erasure) is sufficient as the data-minimisation foundation for EHR deployments. Production readiness requires: (1) Art. 9(2)(a) consent UI and consent record endpoint verified in Stack 4; (2) signed BAAs with all three sub-processors; (3) `VITE_FHIR_CLIENT_ID` populated in CI; (4) Epic SMART on FHIR token-revocation procedure documented in the operator runbook.